

Threat Hunting Report - PEAK Framework

(Assignment 3)

Hunt ID: H-0007

(H for Hypothesis-driven, B for Baseline, M for Model-Assisted)

Hunt Title:

Unauthenticated Command Execution via NimbusDesk ToolShed Panel (NDSA-2026-0007
"TOOLSLED")

PREPARE: Define the Hunt

Hunt Information	Details
Hypothesis	If an adversary has exploited NDSA-2026-0007 ("TOOLSLED") against a NimbusDesk Enterprise Groupware host, then host process-creation telemetry will show the long-running NimbusDesk JVM (java -jar nimbusdesk-toolshed-<version>.jar) spawning a /bin/sh -c child process whose command line contains attacker-controlled shell syntax that does not match the single known-benign hourly self-check (/opt/nimbusdesk/tools/selfcheck.sh). We are hunting for this java-to-shell execution pattern because the vulnerability yields unauthenticated remote code execution (CVSS 9.8) that runs as the nimbus service account, and the resulting shell child is the first host-level artifact that distinguishes exploitation from normal groupware operation.
Threat Hunter Name	Alfred Amoah

Date	August 4, 2026
Requestor	SOC Detection Engineering, in response to vendor advisory NDSA-2026-0007 affecting NimbusDesk builds 4.2.0 - 4.6.3
Timeframe for hunt	5 business days; retrospective sweep across the trailing 30 days of process-creation telemetry, followed by a persistent detection for ongoing coverage

Scoping with the ABLE Methodology

Field	Description	Your Input
Actor	Identifies the adversary behind the behaviour when attribution is known and useful. For a vulnerability-driven hunt like this one, attribution is deliberately left open: the exposure is exploitable by any unauthenticated client that can reach the endpoint, so the hunt is scoped to the exploitation behaviour rather than a named actor.	N/A - this hunt is vulnerability-driven rather than actor-attributed. Any unauthenticated network client capable of reaching the ToolShed Panel can exploit NDSA-2026-0007, so the hunt targets the exploitation behaviour itself rather than a specific named group.
Behavior	States the concrete adversary action the hunt is designed to surface, expressed as observable technique and procedure rather than outcome. This is the falsifiable core of the hypothesis and must be specific enough that its presence or absence can be confirmed directly in telemetry.	Exploitation of NDSA-2026-0007: after an authentication bypass (a spoofed Referer header containing the substring "SignOut.aspx" yields an unauthenticated X-NimbusDesk-ShedToken), the attacker submits a __NIMBUSSTATE form field containing a cmd= action. The vulnerable handler passes the command string directly to Runtime.exec(new String[]{"bin/sh", "-c", cmd}) without sanitisation. On the host this manifests as the

		NimbusDesk JVM spawning a /bin/sh -c child running arbitrary attacker input. Maps to MITRE ATT&CK T1190 (Exploit Public-Facing Application) for initial access and T1059.004 (Command and Scripting Interpreter: Unix Shell) for execution.
Location	Fixes the telemetry boundary of the hunt - the systems and data plane where the behaviour would appear - so the right log sources are queried and the scope stays bounded rather than open-ended.	Host layer - process-creation telemetry on any Linux host running NimbusDesk Enterprise Groupware 4.2.0 - 4.6.3, where the service runs under the unprivileged "nimbus" account from /opt/nimbusdesk/. Scope is limited to hosts exposing the ToolShed Panel endpoint; the corresponding network-layer artifacts are addressed separately by the Suricata coverage in Part 4.
Evidence	Enumerates the specific log sources, the fields within them that carry the signal, and a worked example of what malicious activity looks like in those fields. This is where the hypothesis is proven testable: it confirms, before hunting begins, that the data needed to confirm or refute it actually exists and identifies the exact discriminators separating malicious from benign.	- Source: Linux process-creation telemetry - auditd execve records, or Sysmon for Linux Event ID 1 (Process Creation) - Key Fields: parent_process/ParentImage (expected: java), parent command line (contains nimbusdesk-toolshed-<version>.jar), process/Image (/bin/sh), CommandLine, user (nimbus), timestamp - Example: Parent java -jar /opt/nimbusdesk/lib/nimbusdesk-toolshed-4.6.3.jar spawning /bin/sh -c "echo 'CIS*6580-Assignment3' id" (or any other attacker one-liner), running as user nimbus - a child shell whose command line is NOT the known-benign /opt/nimbusdesk/tools/selfcheck.sh

		- Source: Web/application access logs for the ToolShed Panel endpoint (corroborating network-side artifact) - Key Fields: http_method, uri (/_layouts/15/CIS*6580-Assignment3/ToolShed.aspx), Referer header, X-NimbusDeskShedToken header, request body (_NIMBUSSTATE), body semicolon encoding (raw ";" vs "%3B") - Example: A request whose Referer contains "SignOut.aspx" followed by a POST whose _NIMBUSSTATE body contains a raw, unencoded semicolon and a cmd= action (e.g. _NIMBUSSTATE=RUN;cmd=...). The benign Cloud Uptime Partner PING never carries a spoofed Referer and always percent-encodes its semicolon as %3B (_NIMBUSSTATE=PING%3Bsource%3Dselfcheck).
--	--	---

Example ABLE Inputs

Field	Example Input
Actor	APT29 (Cozy Bear)
Behavior	Credential dumping via mimikatz.exe (T1003)
Location	Corporate Windows Servers
Evidence	- Source: Sysmon Logs (Event ID 1 - Process Creation) - Key Fields: process_name, command_line, parent_process, user, hash - Example: Execution of mimikatz.exe with command line arguments such as "privilege::debug sekurlsa::logonpasswords"

	- Source: Windows Security Event Logs (Event IDs 4624, 4625) - Key Fields: user, source_ip, destination_ip, event_id, timestamp - Example: Successful logon followed by immediate high-privilege process launches consistent with credential extraction attempts
--	--

Threat Intel & Research

- **MITRE ATT&CK Techniques:**
 - T1190 - Exploit Public-Facing Application (Initial Access); T1059.004 - Command and Scripting Interpreter: Unix Shell (Execution); supporting: T1071.001 - Application Layer Protocol: Web (the HTTP exploitation channel)
- **Related Reports, Blogs, or Threat Intel Sources:**
 - NimbusDesk Security Advisory NDSA-2026-0007 "TOOLSLED" (CIS*6580 course material) - primary technical source: vulnerable endpoint, Referer/SignOut.aspx bypass, __NIMBUSSTATE cmd= injection, and the java -> /bin/sh -c process chain
 - MITRE ATT&CK: T1190 (<https://attack.mitre.org/techniques/T1190/>) and T1059.004 (<https://attack.mitre.org/techniques/T1059/004/>); CWE-290 (Authentication Bypass by Spoofing) and CWE-78 (OS Command Injection)
- **Historical Prevalence & Relevance:**
 - No prior exploitation of NDSA-2026-0007 has been confirmed in the environment; this hunt establishes baseline coverage. No existing detection distinguishes the malicious java -> /bin/sh -c chain from the benign hourly "Nimbus Health Sentinel" self-check, which shares the same JVM parent - closing that gap is the primary analytical objective. Mitigation is to upgrade to NimbusDesk 4.6.4+, which replaces the substring Referer check with a signed session-bound nonce and routes cmd actions through an allow-listed dispatcher instead of a shell; this hunt provides interim detection until patching is complete.

EXECUTE: Run the Hunt

Hunting Queries

(Document queries for Splunk, Sigma, KQL, or another query language to execute the hunt. Capture any adjustments made during analysis and iterate on findings.)

Initial Query

*Search Linux process-creation telemetry (auditd execve records or Sysmon for Linux Event ID 1) across the trailing 30 days for any process whose parent command line contains "nimbusdesk-toolshed" (the NimbusDesk JVM) and whose child process image is /bin/sh invoked with the -c argument. From that set, exclude the single known-benign invocation whose child command line is exactly "/bin/sh -c /opt/nimbusdesk/tools/selfcheck.sh" (the hourly Nimbus Health Sentinel self-check). Return every remaining java -> /bin/sh -c event with its full child command line, the executing user, and timestamp, and flag any whose command line contains additional shell metacharacters, network tooling (curl, nc, wget), or the string CIS*6580-Assignment3.*

Notes:

- Confirming evidence: one or more java -> /bin/sh -c events whose parent is the NimbusDesk JVM and whose child command line is anything other than the whitelisted selfcheck.sh confirms the hypothesis - exploitation has occurred. Corroborate against the web access logs for a matching request bearing a "SignOut.aspx" Referer and a raw-semicolon __NIMBUSSTATE=...;cmd= body.
- Refuting evidence: if the only java -> shell events observed are the hourly selfcheck.sh invocations, the hypothesis is refuted for the hunt window - no exploitation is present. Known false-positive source is precisely that hourly self-check, which is excluded by command-line match; a gap exists only if process-creation logging is disabled on a host, which must be validated as a prerequisite.
Refinement: if the environment runs multiple NimbusDesk versions, broaden the parent match from a fixed version to the "nimbusdesk-toolshed-" prefix; if selfcheck.sh is ever invoked with varying arguments, tighten the exclusion to an exact-path anchor so it cannot be abused by an attacker to hide a malicious command behind the whitelisted string.

References

- NimbusDesk Security Advisory NDSA-2026-0007 "TOOLSLED" - NimbusDesk ToolShed Panel Authentication Bypass & Unauthenticated Command Execution (CIS*6580 course material, University of Guelph)
- MITRE ATT&CK T1190 - <https://attack.mitre.org/techniques/T1190/> ; MITRE ATT&CK T1059.004 - <https://attack.mitre.org/techniques/T1059/004/> ; CWE-290 - <https://cwe.mitre.org/data/definitions/290.html> ; CWE-78 - <https://cwe.mitre.org/data/definitions/78.html>